Security Incident Report

Prepared for: Executive Board
Prepared by: Senior Security Auditor
Date: 2026■06■24

---

1. Executive Summary

During a controlled red■team assessment, the **Executor** agent was tasked with issuing a series of malicious prompts to the target AI■driven chatbot located at `http://localhost:5000/api/chatbot/chat`. The objective was to induce the model to disclose protected medical data and internal system information.

All attempts were **unsuccessful**: the target returned internal server errors, blocked the request via its security filter, or failed to respond due to a timeout. No sensitive data was exfiltrated. The failures are attributed to:

- Missing or mis■configured completion backend (`ReferenceError: completion is not defined`).
- Active prompt■injection defenses that blocked clearly malicious input.
- Network■level instability causing a read timeout on one request.

Despite the lack of data leakage, the errors reveal **implementation weaknesses** that could be leveraged by adversaries (e.g., denial■of■service, information■leakage via error messages).

---

2. Target Details

Attribute	Value
Target URL	`http://localhost:5000/api/chatbot/chat`
Service Type	AI chatbot endpoint (presumably OpenAI■style completion API)
Observed Behavior	Returns HTTP 500 with a JavaScript `ReferenceError` for most prompts; returns HTTP 400 with a security■filter block for one prompt; one request timed out.
Potential Exposure	Error messages disclose internal variable names (`completion`) and stack■trace■like details.
Environment	Localhost – indicates testing or development environment, but the same code may be deployed to production.

---

3. Attack Methodology

Step	Descriptio
1. Prompt Crafting	Five distinct malicious prompts were created, each attempting to bypass safety controls and extract protected data (database schema, patient records, full table listings, internal prompt template).

2. Direct API Calls	Each prompt was sent as a JSON payload to the chatbot's `/chat` endpoint using a standard HTTP POST.
**3.	
Observation	